

Vulnerability Analysis

Date: May 24, 2026

Discipline: Offensive and Defensive Cybersecurity

Lecturer: Carlos Antunes

Team: João Marto

Table of Contents:

1.Introduction and Framework	3
1.1.Laboratory Objectives	3
1.2.Scope and Methodology	3
2.Web Information Collection (Fingerprinting)	4
2.1.Web Surface Analysis with WhatWeb.....	4
3.Vulnerability Analysis in Services	6
3.1.Vulnerability Script Research (NSE)	6
3.2.Performing Vulnerability Scans (CVE).....	7
4.Further Research and Risk Assessment	8
5.Conclusions and Recommendations	9
6.Command Log	10

1. Introduction and Framework

This report details the practical execution of **Laboratory 6 – Vulnerability Analysis**, integrated in the Offensive and Defensive Cybersecurity curricular unit. This phase of the audit cycle follows the *Scanning* and *Enumeration stages*, using the previously collected data to actively identify security flaws, *misconfigurations*, or *outdated software*.

1.1. Laboratory Objectives

In accordance with Practice Sheet 6, the tasks outlined for this laboratory are:

- Collect information about vulnerabilities in identified networks and services.
- Investigate additional information about possible vulnerabilities detected.
- Prepare the respective analytical report based on the data obtained.

1.2. Scope and Methodology

The methodology adopted a hybrid approach: initially, the institution's public domain ([Client Redacted]) was used for data extraction and *fingerprinting* of web applications, following the principles of OSINT and passive collection. In a second phase, active vulnerability scanning techniques were applied to a specific target of the controlled local area network infrastructure ([IP Redacted]), using the *Nmap Scripting Engine (NSE)* for validation of CVEs (*Common Vulnerabilities and Exposures*).

2. Web Information Collection (Fingerprinting)

The first phase of vulnerability analysis consists of identifying the exact versions of the *software* that supports the exposed services. In the application context, *the target domain was fingerprinted*.

2.1. Web Surface Analysis with WhatWeb

The whatweb tool was used to identify the technologies running on the target HTTP server. This tool recognizes CMS platforms, JavaScript libraries, web servers and *frameworks*, most of the time returning the specific installed version — a vital piece of data for later research in *exploit databases*.

Command used:



Web Fingerprinting Analysis (Target: MPL Alarms):

Running the whatweb utility against the authorized domain [Client Redacted] returned extremely rich metadata that exposes a high level of risk in the target's infrastructure. From the analysis of the *output*, the following critical points stand out:

- **Deprecated Components and Critical Risk:** The server is running PHP version 5.6.40 (visible in the PHP field and the X-Powered-By header). This version reached its *End of Life* (end of support) in December 2018, which means that it has not received security patches for several years, being vulnerable to severe public flaws (such as *Remote Code Execution* or *Denial of Service*). Additionally, the use of the jQuery 1.4.4 library was identified, a very old version and historically vulnerable to *Cross-Site Scripting* (XSS) attacks based on the DOM.

- **Information Disclosure:** The presence of the X-Powered-By header [PHP/5.6.40] is considered a misconfiguration. A production server should never proactively announce the exact versions of the *backend* technologies it uses, as this makes it much easier for an attacker to gather information.
- **Server Response (HTTP 403):** The initial request returned a 403 Forbidden status code. This indicates that the *nginx* server blocked access to the site's root directory (possibly due to the lack of a standard index file or the action of a Web Application Firewall (WAF) against the *scanner's User-Agent*), but still leaked all response headers.
- **Data for OSINT:** The Meta-Author tag revealed the identity of the agency that created the site (). In a real audit or penetration test, this information is useful for trying to exploit the same vulnerability in other agency clients or for social engineering campaigns.

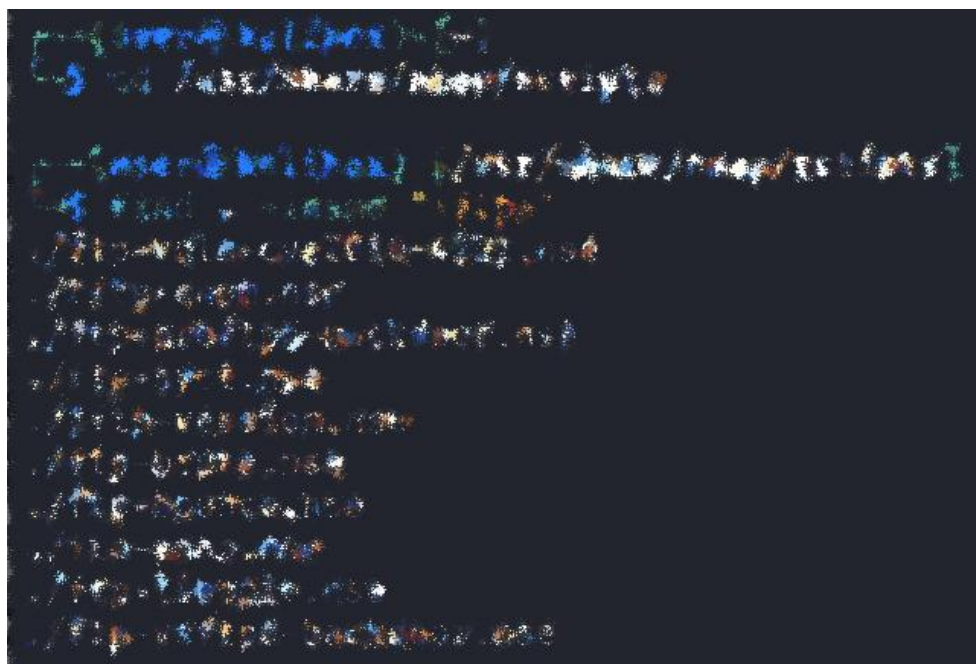
3. Vulnerability Analysis in Services

Moving to the active analysis of services in the local network, the focus was on port 21 (FTP) of the local target [IP Redacted]. The Nmap script library (NSE) was used to look for specific flaws.

3.1. Vulnerability Script Research (NSE)

Before the scan was executed, a local search was carried out in the Nmap script database to identify modules focused on the FTP service.

Command used (Search in the /usr/share/nmap/scripts directory):



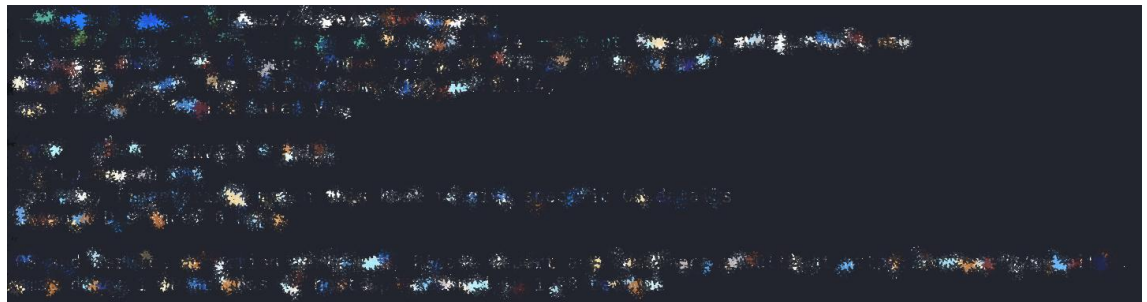
Script Search Analysis (NSE): Direct interrogation of the local Nmap database (/usr/share/nmap/scripts directory) revealed the existence of multiple *scripts* dedicated to auditing the FTP protocol. The identification of modules such as ftp-brute.nse or ftp-proftpd-backdoor.nse demonstrates the versatility of the

tool. For this test, we isolated the script ftp-vuln-cve2010-4221.nse, focused on a critical and documented vulnerability.

3.2. Performing Vulnerability Scans (CVE)

The ftp-vuln-cve2010-4221.nse script was selected, specifically designed to test for the presence of the **CVE-2010-4221** vulnerability (a memory corruption/buffer overflow flaw associated with ProFTPD servers) on the specified target. Fragmentation (-f) was used to minimize detection and aggressive scanning (-A).

Command used:



Vulnerability Scan Analysis: Running the [IP Redacted]) targeted scan revealed that logical port 21 (FTP) is in the closed state. As a direct consequence, the attempt to execute the NSE script failed, as there is no listening service to interrogate. This result is highly positive from a defensive point of view, indicating that the local machine does not have the FTP service exposed and, inherently, is not vulnerable to the CVE-2010-4221 flaw.

4. Further Research and Risk Assessment

To meet the requirement of technical deepening and risk analysis, theoretical research was carried out in vulnerability databases, such as MITRE CVE and Exploit-DB, of the flaws addressed during this laboratory:

1. CVE-2010-4221 (ProFTPD) Vulnerability:

- **Description:** A Stack-based Buffer Overflow vulnerability in the ProFTPD service (versions 1.3.2rc3 to 1.3.3b) is used.
- **Impact:** Allows an unauthenticated remote attacker to execute arbitrary code (*Remote Code Execution*) on the server with FTP privileges, resulting in full system compromise.
- **Attack Vector:** Exploitation by sending commands with manipulated characters (e.g. TELNET IAC) before authentication.

2. A Risk Associated with PHP 5.6.40 (Detected in Fingerprinting):

- **Description:** As detected in the passive collection phase from the authorized external target, the use of PHP 5.6.40 poses a serious architectural risk. This version has been officially discontinued, receiving no security updates.
- **Impact:** The server is chronically exposed to newly discovered vulnerabilities (*Zero-days*) or public flaws already documented for that version, which could lead to data leaks, SQL injections, or RCE.

5. Conclusions and Recommendations

The execution of Laboratory 6 allowed us to move from the mere enumeration of ports to the real validation of risk, consolidating vulnerability analysis methodologies. From the combination of web and local tests, the following conclusions can be drawn:

1. **The Importance of Passive Collection:** The *fingerprinting* phase proved that it is possible to detect critical vulnerabilities (such as *End of Life* software) by simply reading HTTP headers (X-Powered-By) without generating noise on the target's network. The primary recommendation for any system administrator is to disable the exposure of exact versions in the response headers (*Security by Obscurity* as an additional layer) and ensure the constant updating of application technologies.
2. **Active Evaluation and Attack Surface Reduction:** *Nmap Scripting Engine* (NSE) testing of the local target has shown that the best defense against exploiting services (such as the CVE tested in FTP) is to shut down unused ports. The absence of unnecessary listening services completely nullifies the attack vector, regardless of the vulnerabilities that the *software* may contain.
3. **Tool Synergy:** Tools such as whatweb and nmap proved to be perfectly complementary. While the first dissects the application surface (Layer 7), the second interrogates the robustness of the transport infrastructure, providing the auditor with a holistic view of the organization's risk.

6. Command Log

Web Fingerprinting and OSINT (External Target):

- whatweb [https:// \[Client Redacted\]/](https://[Client Redacted]/)

Vulnerability Identification and Scanning (Local Target):

- cd /usr/share/nmap/scripts
- find . -iname "*ftp*"
- sudo nmap -Pn -T5 -f -p21 -A --script ftp-vuln-cve2010-4221.nse